

Relazione di Laboratorio – Deploy e Configurazione di Gophish in Ambiente Sandbox (Mailtrap)

Studente: Simone Santonico

Data: 06/05/2026

1. Obiettivo dell'attività

Il laboratorio aveva come finalità la messa in opera di Gophish, piattaforma open-source utilizzata per simulazioni controllate di phishing. L'intero setup è stato realizzato in un ambiente isolato, sfruttando Mailtrap come server SMTP di test. Questa scelta permette di verificare il funzionamento delle campagne senza correre il rischio di inviare email indesiderate verso caselle reali, garantendo così un contesto totalmente sicuro per sperimentare l'invio, il tracciamento dei link e la raccolta delle credenziali.

2. Installazione e Avvio da Linea di Comando

La fase iniziale si è svolta interamente tramite CLI e ha previsto tre passaggi principali:

- Download del pacchetto: tramite wget è stata scaricata la release compatibile (v0.12.1 per Linux 64-bit) direttamente dalla repository GitHub del progetto.
- Estrazione e permessi: con unzip gophish-*.zip è stato estratto l'archivio e, una volta entrati nella cartella, è stato necessario rendere eseguibile il binario con chmod +x gophish, poiché per impostazione predefinita non dispone dei permessi di esecuzione.
- Avvio del servizio: eseguendo ./gophish sono comparsi nel terminale diversi messaggi utili:
- Password temporanea: Gophish genera automaticamente una credenziale provvisoria per l'utente admin (nel nostro caso: 0b370c8eaa53663a), da utilizzare esclusivamente per il primo accesso.
- Porte in ascolto: la dashboard amministrativa risponde su https://127.0.0.1:3333, mentre il server dedicato alle landing page è esposto su http://0.0.0.0:80.

3. Configurazione tramite Interfaccia Web

Una volta avviato il servizio, la configurazione si è spostata sulla dashboard di Gophish, dove sono stati predisposti gli elementi necessari per una campagna di test completa.

- Profilo SMTP (Mailtrap): è stato creato un nuovo Sending Profile utilizzando l'host sandbox.smtp.mailtrap.io e le credenziali fornite dalla inbox di Mailtrap. Un test di invio ha confermato che i messaggi vengono correttamente intercettati dalla sandbox.
- Landing Page: è stata realizzata una pagina HTML contenente un form di login. Per permettere a Gophish di registrare i dati inseriti, è stato verificato che il form utilizzasse method="POST" e che fossero attive le opzioni Capture Submitted Data e Capture Passwords.
- Template dell'email: il corpo del messaggio di phishing è stato redatto inserendo la variabile {{.URL}}, che Gophish sostituisce automaticamente con un link personalizzato per ogni destinatario, consentendo il tracciamento dei clic.

4. Considerazioni Finali e Aspetti di Sicurezza

L'attività ha messo in evidenza alcuni punti chiave legati alla sicurezza e al corretto utilizzo dello strumento:

- Perché usare Mailtrap: l'ambiente sandbox elimina il rischio di inviare accidentalmente email a utenti reali. Anche in caso di errore nella configurazione dei destinatari, i messaggi rimangono confinati nella casella di test.
- Importanza dei log di Gophish: il fatto che la password iniziale venga generata dinamicamente e mostrata solo all'avvio rappresenta un approccio secure by default. Evita l'uso di credenziali predefinite e obbliga l'amministratore a modificarle subito, riducendo la superficie di attacco.